RAPPORT D'AUDIT · QUALITÉ & SÉCURITÉ

Expense.io

État des lieux de l'application de notes de frais avant sa refonte : ce qui ne va pas, pourquoi c'est important, et dans quel ordre le corriger.

Date : 12 octobre 2026 (audit initial du 9 octobre 2026)
Périmètre : application web, API et base de données
Constats : 38 problèmes, dont 4 critiques

Ce document est la version lisible du rapport technique `docs/audit/AUDIT.md`. Les numéros de constat (F1 à F38) sont les mêmes dans les deux documents ; le rapport technique donne en plus le détail de reproduction et les extraits de code.

En bref

L'essentiel du rapport en une page.

L'application fonctionne pour une démonstration, mais elle n'est pas prête à accueillir de vraies entreprises. L'audit relève 38 problèmes. Les plus graves touchent au cloisonnement entre entreprises : aujourd'hui, un manager peut consulter les justificatifs d'une autre société, un utilisateur connecté peut détourner une requête vers la base de données, et toute personne ayant accès au code peut se faire passer pour n'importe quel utilisateur.

La bonne nouvelle : les corrections les plus urgentes sont pour la plupart localisées et rapides à faire.

4	8	16	10
CRITIQUES	**ÉLEVÉS**	**MOYENS**	**FAIBLES**
à corriger avant toute mise en service	fuite, panne ou perte de donnée	gêne métier ou fragilité	correction souhaitable

Les cinq corrections à faire en premier

1. Empêcher les managers de lire les reçus d'autres entreprises. F1
2. Fermer la faille d'injection sur le tri des notes. F3
3. Sortir la clé secrète des sessions du code et la remplacer. F25
4. Connecter l'application à la base avec un compte sans privilèges d'administration. F2
5. Interdire de rattacher un employé à un manager d'une autre entreprise. F5

Ce qui fonctionne bien

- Approuver ou rejeter une note respecte la hiérarchie et l'entreprise : toute tentative hors périmètre est refusée.
- Un employé ne voit que ses propres notes et ses propres reçus.
- Les mots de passe sont stockés chiffrés, et le fichier de configuration local n'est pas versionné.
- Les requêtes à la base sont paramétrées partout, sauf pour le tri (F3).

Comment lire ce rapport

Chaque problème reçoit une gravité et un niveau de vérification.

CRITIQUE	Permet de compromettre l'application ou de corrompre directement des données. À corriger avant toute mise en service.
ÉLEVÉ	Fuite de données entre entreprises, panne réaliste ou perte de donnée.
MOYEN	Gêne nettement l'usage métier ou fragilise l'application.
FAIBLE	Correction souhaitable, sans urgence.
● Vérifié	Reproduit sur l'application en fonctionnement, avec de vrais comptes pour chaque rôle.
○ Lu dans le code	Établi par lecture du code source ; pas encore reproduit sur l'application en marche.

Les rôles cités : **employé** (soumet des notes de frais), **manager** (valide les notes des employés qui lui sont rattachés), **RH** (gère l'organigramme et valide les notes des managers qui n'ont pas eux-mêmes de manager).

Vue d'ensemble

Les 38 constats, du plus grave au moins grave.

N°	PROBLÈME	THÈME	GRAVITÉ	VÉRIFICATION
F1	Un manager peut voir les justificatifs de n'importe quelle entreprise	Cloisonnement des données	CRITIQUE	● Vérifié
F2	La protection intégrée à la base de données est contournée	Cloisonnement des données	CRITIQUE	● Vérifié
F3	Injection SQL possible via le tri de la liste des notes	Cloisonnement des données	CRITIQUE	● Vérifié
F25	La clé qui protège les sessions est écrite dans le code	Sécurité technique	CRITIQUE	○ Lu dans le code
F4	Le premier inscrit d'un domaine devient RH, sans vérification	Comptes, entreprises et rôles	ÉLEVÉ	● Vérifié
F5	La RH peut rattacher un employé à un manager d'une autre entreprise	Comptes, entreprises et rôles	ÉLEVÉ	● Vérifié
F9	Deux décisions simultanées sur une note peuvent toutes deux réussir	Fiabilité des données	ÉLEVÉ	● Vérifié
F16	Aucun index sur les données les plus consultées	Performances et limites	ÉLEVÉ	● Vérifié
F17	La lecture automatique des reçus est lente et gourmande	Performances et limites	ÉLEVÉ	● Vérifié

N°	PROBLÈME	THÈME	GRAVITÉ	VÉRIFICATION
F19	Aucune limite de taille pour la lecture automatique des reçus	Performances et limites	ÉLEVÉ	○ Lu dans le code
F26	Les messages d'erreur exposent l'intérieur du serveur	Sécurité technique	ÉLEVÉ	● Vérifié
F30	L'organigramme peut tourner en boucle	Comptes, entreprises et rôles	ÉLEVÉ	○ Lu dans le code
F6	Une entreprise se résume à un nom de domaine	Comptes, entreprises et rôles	MOYEN	○ Lu dans le code
F7	Les majuscules dans l'email posent problème	Comptes, entreprises et rôles	MOYEN	● Vérifié
F10	Une note peut être enregistrée sans son reçu	Fiabilité des données	MOYEN	○ Lu dans le code
F11	Une inscription ratée peut laisser une entreprise sans RH	Fiabilité des données	MOYEN	○ Lu dans le code
F13	Un montant très élevé fait échouer l'envoi	Fiabilité des données	MOYEN	● Vérifié
F14	Personne ne peut valider les notes de frais d'une RH	Parcours métier et interface	MOYEN	● Vérifié
F15	L'employé n'est jamais prévenu de la décision	Parcours métier et interface	MOYEN	● Vérifié
F18	Les listes ne sont pas paginées	Performances et limites	MOYEN	● Vérifié
F20	Aucune limite au nombre de tentatives	Performances et limites	MOYEN	○ Lu dans le code
F21	Les traitements lourds font attendre l'utilisateur	Performances et limites	MOYEN	○ Lu dans le code
F22	Une partie de l'architecture n'est pas utilisée	Qualité du code	MOYEN	● Vérifié
F31	Un changement de rôle n'est pris en compte qu'à la reconnexion	Comptes, entreprises et rôles	MOYEN	○ Lu dans le code
F32	La date de la dépense n'est pas vérifiée	Fiabilité des données	MOYEN	○ Lu dans le code
F33	Un nouvel employé n'a personne pour valider ses notes	Parcours métier et interface	MOYEN	○ Lu dans le code
F34	La limite de 10 Mo ne protège pas le serveur	Performances et limites	MOYEN	○ Lu dans le code
F35	Aucun test automatisé	Qualité du code	MOYEN	○ Lu dans le code
F8	Impossible de nommer un manager depuis l'application	Comptes, entreprises et rôles	FAIBLE	○ Lu dans le code

N°	PROBLÈME	THÈME	GRAVITÉ	VÉRIFICATION
F12	Deux inscriptions simultanées avec le même email provoquent une erreur	Fiabilité des données	FAIBLE	○ Lu dans le code
F23	Le même code est recopié en cinq endroits	Qualité du code	FAIBLE	● Vérifié
F24	Des utilitaires ne sont jamais utilisés	Qualité du code	FAIBLE	● Vérifié
F27	Les codes d'erreur sont incohérents	Qualité du code	FAIBLE	● Vérifié
F28	Aucun historique des décisions	Parcours métier et interface	FAIBLE	○ Lu dans le code
F29	Plusieurs défauts d'affichage	Parcours métier et interface	FAIBLE	● Vérifié
F36	On peut deviner quels emails ont un compte	Sécurité technique	FAIBLE	○ Lu dans le code
F37	Le contenu des fichiers envoyés n'est pas vérifié	Sécurité technique	FAIBLE	○ Lu dans le code
F38	Des fonctions attendues manquent	Parcours métier et interface	FAIBLE	○ Lu dans le code

1. Cloisonnement des données

Chaque entreprise ne doit voir que ses propres données. Aujourd'hui, cette séparation repose sur une seule barrière, et cette barrière a des trous.

F1 Un manager peut voir les justificatifs de n'importe quelle entreprise

CRITIQUE · Vérifié

CE QUI SE PASSE
Pour afficher un reçu, l'application vérifie seulement que la personne est manager, pas que la note appartient à l'un de ses employés. Testé : un manager de l'entreprise A a récupéré le reçu d'une note de l'entreprise B.

POURQUOI C'EST UN PROBLÈME
Les reçus contiennent des données personnelles et commerciales. Leurs noms de fichiers se suivent (1, 2, 3…), et le lien obtenu fonctionne cinq minutes sans être connecté : il peut être transmis à n'importe qui.

CE QU'IL FAUT FAIRE
Appliquer à l'affichage du reçu le même contrôle qu'à l'approbation : la note doit appartenir à un employé rattaché à ce manager.

`api/manager/expense-notes/[id]/receipt-url/route.ts:17`

F2 La protection intégrée à la base de données est contournée

CRITIQUE · Vérifié

CE QUI SE PASSE
La base contient des règles censées empêcher chaque utilisateur de lire les données des autres. Mais l'application s'y connecte avec un compte administrateur, qui ignore ces règles.

POURQUOI C'EST UN PROBLÈME
Il ne reste qu'une seule barrière : chaque écran doit penser à filtrer lui-même les données. Le moindre oubli, comme en F1, devient une fuite.

CE QU'IL FAUT FAIRE
Connecter l'application avec un compte sans privilèges d'administration, pour que les règles de la base s'appliquent réellement.

`rôle PostgreSQL expense (superuser) · migrations/1700000000001_init-schema.sql`

F3 Injection SQL possible via le tri de la liste des notes

CRITIQUE · Vérifié

CE QUI SE PASSE
Le paramètre qui choisit l'ordre de tri des notes est inséré tel quel dans la requête envoyée à la base. Testé : une valeur arbitraire arrive bien jusqu'à la base.

POURQUOI C'EST UN PROBLÈME
Un utilisateur connecté peut y glisser ses propres instructions et lire des données auxquelles il n'a pas droit. Avec F2, rien ne l'arrête au niveau de la base.

CE QU'IL FAUT FAIRE
N'accepter qu'une liste fixe de tris autorisés, et refuser toute autre valeur.

`api/expense-notes/route.ts:42-46`

2. Comptes, entreprises et rôles

Comment on rejoint une entreprise, quels droits on y reçoit, et comment l'organigramme est géré.

F4 Le premier inscrit d'un domaine devient RH, sans vérification

ÉLEVÉ · ● Vérifié

CE QUI SE PASSE	L'entreprise est déduite du domaine de l'adresse email. La première personne qui s'inscrit avec un domaine devient automatiquement RH de cette entreprise, et l'adresse n'est jamais vérifiée.
POURQUOI C'EST UN PROBLÈME	N'importe qui peut « fonder » l'entreprise d'un autre en s'inscrivant le premier. Sur un domaine public comme gmail.com, le premier inscrit devient RH de tous les comptes Gmail.
CE QU'IL FAUT FAIRE	Vérifier l'adresse email, et attribuer le rôle RH explicitement (invitation, validation) plutôt qu'au premier arrivé.

`app/actions/auth.ts:41-63`

F5 La RH peut rattacher un employé à un manager d'une autre entreprise

ÉLEVÉ · ● Vérifié

CE QUI SE PASSE	Lors d'un rattachement, l'application vérifie que la personne choisie est manager, mais pas qu'elle appartient à la même entreprise. Testé avec succès entre deux entreprises.
POURQUOI C'EST UN PROBLÈME	Un manager extérieur peut alors valider les notes de frais de cet employé et consulter ses justificatifs.
CE QU'IL FAUT FAIRE	Exiger que le manager choisi appartienne à l'entreprise de la RH.

`api/hr/users/[id]/manager/route.ts:39-41`

F30 L'organigramme peut tourner en boucle

ÉLEVÉ · ○ Lu dans le code

CE QUI SE PASSE	La RH peut rattacher un manager A à un manager B, puis B à A. Seul le cas « être son propre manager » est bloqué.
POURQUOI C'EST UN PROBLÈME	Chacun valide alors les notes de l'autre : deux managers peuvent s'approuver mutuellement leurs dépenses. Et comme aucun des deux n'est plus en haut de l'organigramme, leurs notes disparaissent de la vue RH.
CE QU'IL FAUT FAIRE	Refuser tout rattachement qui créerait une boucle : le manager choisi ne doit pas être un subordonné de la personne.

`api/hr/users/[id]/manager/route.ts:32`

F6 Une entreprise se résume à un nom de domaine

MOYEN · Lu dans le code

CE QUI SE PASSE
Chaque entreprise est identifiée uniquement par le domaine des adresses email de ses salariés.

POURQUOI C'EST UN PROBLÈME
Une société qui a plusieurs domaines (acme.com et acme.fr) se retrouve découpée en entreprises séparées, et deux sociétés différentes peuvent porter le même nom affiché (acme.com et acme.io deviennent toutes deux « acme »).

CE QU'IL FAUT FAIRE
Gérer l'entreprise comme une entité à part entière, pouvant avoir plusieurs domaines et des invitations.

`table companies (email_domain) · app/actions/auth.ts:42`

F7 Les majuscules dans l'email posent problème

MOYEN · Vérifié

CE QUI SE PASSE
« Demo@Expense.io » ne permet pas de se connecter au compte « demo@expense.io », et l'on peut créer deux comptes qui ne diffèrent que par les majuscules.

POURQUOI C'EST UN PROBLÈME
Des utilisateurs bloqués à la connexion, et des doublons de comptes pour une même personne.

CE QU'IL FAUT FAIRE
Enregistrer et comparer les emails en minuscules, et interdire les doublons quelle que soit la casse.

`lib/auth.ts:33 · app/actions/auth.ts:36`

F31 Un changement de rôle n'est pris en compte qu'à la reconnexion

MOYEN · Lu dans le code

CE QUI SE PASSE
Le rôle est enregistré dans la session au moment de la connexion et n'est plus jamais revérifié. Il n'existe pas non plus de moyen de déconnecter quelqu'un à distance.

POURQUOI C'EST UN PROBLÈME
Une personne rétrogradée ou supprimée garde ses droits jusqu'à 30 jours. Impossible de couper l'accès d'un compte piraté ou d'un salarié qui quitte l'entreprise.

CE QU'IL FAUT FAIRE
Revérifier le rôle en base régulièrement, raccourcir la durée des sessions et prévoir un moyen de les révoquer.

`lib/auth.ts:45-58`

F8 Impossible de nommer un manager depuis l'application

FAIBLE · Lu dans le code

CE QUI SE PASSE	Aucun écran ne permet de donner le rôle de manager à un employé ; cela ne peut se faire que directement dans la base.
POURQUOI C'EST UN PROBLÈME	L'organisation ne peut pas évoluer sans intervention technique.
CE QU'IL FAUT FAIRE	Permettre à la RH de changer le rôle d'un utilisateur, ou acter explicitement cette limite.

`api/hr/users`

3. Fiabilité des données

Situations où les données enregistrées deviennent fausses, incomplètes ou incohérentes.

F9 Deux décisions simultanées sur une note peuvent toutes deux réussir

ÉLEVÉ · Vérifié

CE QUI SE PASSE	Si « approuver » et « rejeter » sont envoyés au même moment sur la même note, les deux sont acceptés. Testé : les deux réponses indiquent un succès.
POURQUOI C'EST UN PROBLÈME	L'état final est aléatoire, une décision est perdue sans que personne ne le sache, et deux personnes reçoivent des confirmations contradictoires.
CE QU'IL FAUT FAIRE	N'enregistrer la décision que si la note est encore « en attente » au moment de l'écriture, et signaler sinon qu'elle a déjà été traitée.

`routes approve / reject, manager et RH (ligne 28)`

F10 Une note peut être enregistrée sans son reçu

MOYEN · Lu dans le code

CE QUI SE PASSE	La note est enregistrée avant l'envoi du reçu. Si l'envoi du reçu échoue, la note reste en base sans justificatif.
POURQUOI C'EST UN PROBLÈME	Des notes incomplètes, impossibles à vérifier, apparaissent dans les listes de validation.
CE QU'IL FAUT FAIRE	Envoyer le reçu d'abord, ou supprimer la note si l'envoi échoue.

`api/expense-notes/route.ts:88-106`

F11 Une inscription ratée peut laisser une entreprise sans RH

MOYEN · ○ Lu dans le code

CE QUI SE PASSE	L'inscription crée l'entreprise puis l'utilisateur, en deux étapes indépendantes.
POURQUOI C'EST UN PROBLÈME	Si la seconde étape échoue, l'entreprise existe sans personne dedans, et le prochain inscrit de ce domaine arrive comme simple employé : l'entreprise n'a plus de RH.
CE QU'IL FAUT FAIRE	Réaliser les deux étapes en une seule opération, qui réussit ou échoue en entier.

`app/actions/auth.ts:36-69`

F13 Un montant très élevé fait échouer l'envoi

MOYEN · ● Vérifié

CE QUI SE PASSE	Au-delà de 99 999 999,99 €, l'envoi échoue avec une erreur technique au lieu d'un message clair.
POURQUOI C'EST UN PROBLÈME	L'utilisateur ne comprend pas ce qui se passe, et l'erreur affiche des détails internes du serveur (voir F26).
CE QU'IL FAUT FAIRE	Vérifier le montant avant de l'enregistrer et afficher un message compréhensible.

`api/expense-notes/route.ts:69-73`

F32 La date de la dépense n'est pas vérifiée

MOYEN · ○ Lu dans le code

CE QUI SE PASSE	Le serveur ne contrôle ni le format ni la vraisemblance de la date : une date invalide provoque une erreur technique, une date future ou en 1900 est acceptée. La description n'a pas de longueur maximale.
POURQUOI C'EST UN PROBLÈME	Des notes incohérentes entrent dans la base, et un texte de plusieurs mégaoctets ralentit toutes les listes où il apparaît.
CE QU'IL FAUT FAIRE	Valider le format de la date, refuser les dates futures ou trop anciennes, et limiter la longueur de la description.

`api/expense-notes/route.ts:74`

F12 Deux inscriptions simultanées avec le même email provoquent une erreur

FAIBLE · ○ Lu dans le code

CE QUI SE PASSE	Si deux inscriptions avec la même adresse arrivent au même instant, l'une échoue avec une erreur technique au lieu d'un message clair.
POURQUOI C'EST UN PROBLÈME	Cas rare, mais qui affiche des détails internes du serveur (voir F26).
CE QU'IL FAUT FAIRE	Gérer proprement le cas « compte déjà existant » au moment même de l'enregistrement.

`app/actions/auth.ts:36, 66`

4. Parcours métier et interface

Situations où l'application empêche d'aller au bout d'une démarche, ou affiche des informations trompeuses.

F14 Personne ne peut valider les notes de frais d'une RH

MOYEN · ● Vérifié

CE QUI SE PASSE	Une RH peut soumettre une note, mais celle-ci n'apparaît dans aucune liste de validation. Testé.
POURQUOI C'EST UN PROBLÈME	La note reste « en attente » indéfiniment, sans que personne ne s'en aperçoive.
CE QU'IL FAUT FAIRE	Décider qui valide les notes d'une RH (une autre RH, par exemple), ou empêcher la soumission.

`api/hr/expense-notes/route.ts:29`

F15 L'employé n'est jamais prévenu de la décision

MOYEN · ● Vérifié

CE QUI SE PASSE	Le code d'envoi des notifications existe, mais il n'est appelé nulle part.
POURQUOI C'EST UN PROBLÈME	L'employé doit revenir vérifier lui-même si sa note a été approuvée ou rejetée.
CE QU'IL FAUT FAIRE	Envoyer une notification à chaque décision, de préférence en arrière-plan.

`adapters/ConsoleNotificationAdapter.ts`

F33 Un nouvel employé n'a personne pour valider ses notes

MOYEN · Lu dans le code

CE QUI SE PASSE
Tout employé qui s'inscrit n'a pas de manager tant que la RH ne l'a pas rattaché. En attendant, ses notes ne sont visibles par personne, ni manager ni RH.

POURQUOI C'EST UN PROBLÈME
C'est la situation par défaut de chaque nouvel employé : ses premières notes restent bloquées sans aucune alerte, ni pour lui, ni pour la RH.

CE QU'IL FAUT FAIRE
Faire remonter à la RH les notes des employés sans manager, et signaler dans l'espace RH les employés non rattachés.

`app/actions/auth.ts:66 · api/hr/expense-notes/route.ts:29`

F28 Aucun historique des décisions

FAIBLE · Lu dans le code

CE QUI SE PASSE
Une fois approuvée ou rejetée, une note ne peut plus changer, et rien n'indique qui a pris la décision ni quand.

POURQUOI C'EST UN PROBLÈME
Pas de correction possible d'une erreur de clic, et aucune traçabilité en cas de contrôle.

CE QU'IL FAUT FAIRE
Enregistrer chaque décision avec son auteur et sa date, et prévoir une annulation encadrée.

`table expense_notes`

F29 Plusieurs défauts d'affichage

FAIBLE · Vérifié

CE QUI SE PASSE
Les dates peuvent s'afficher avec un jour de décalage selon le fuseau horaire ; le manager voit un identifiant technique au lieu du nom de l'employé ; le total de l'employé compte aussi les notes rejetées et en attente ; les rôles sont affichés en anglais.

POURQUOI C'EST UN PROBLÈME
Des informations fausses ou incompréhensibles pour l'utilisateur.

CE QU'IL FAUT FAIRE
Corriger chacun de ces points (le détail est dans le rapport technique).

`expenses/page.tsx · PendingApprovalsPanel.tsx · AdminConsole.tsx`

F38 Des fonctions attendues manquent

FAIBLE · ○ Lu dans le code

CE QUI SE PASSE	Un employé ne peut ni modifier ni annuler une note en attente ; un rejet ne précise jamais son motif ; il n'existe pas de parcours « mot de passe oublié ».
POURQUOI C'EST UN PROBLÈME	Une simple faute de frappe oblige à faire rejeter la note, et l'employé ne sait pas quoi corriger.
CE QU'IL FAUT FAIRE	À arbitrer avec les utilisateurs métier. Le motif de rejet peut rejoindre l'historique proposé en F28.

_

5. Performances et limites

Ce qui ralentira l'application quand elle grandira, ou permettrait à quelqu'un de la rendre indisponible.

F16 Aucun index sur les données les plus consultées

ÉLEVÉ · ● Vérifié

CE QUI SE PASSE	La base n'a pas d'index sur les colonnes qui servent à retrouver les notes d'un employé ou les employés d'un manager : chaque recherche parcourt toute la table.
POURQUOI C'EST UN PROBLÈME	Invisible aujourd'hui, mais les listes ralentiront nettement dès quelques milliers de notes.
CE QU'IL FAUT FAIRE	Ajouter des index sur l'auteur et le statut des notes, ainsi que sur le manager et l'entreprise des utilisateurs.

`migrations/1700000000001_init-schema.sql`

F17 La lecture automatique des reçus est lente et gourmande

ÉLEVÉ · ● Vérifié

CE QUI SE PASSE	Le bouton « Pré-remplir depuis le reçu » relance la reconnaissance de texte à partir de zéro à chaque clic : chargement du moteur et de la langue, analyse, puis tout est jeté.
POURQUOI C'EST UN PROBLÈME	L'utilisateur attend plusieurs secondes, et quelques clics simultanés suffisent à saturer le processeur et la mémoire du serveur.
CE QU'IL FAUT FAIRE	Garder le moteur chargé et le réutiliser, limiter le nombre d'analyses en parallèle, et traiter l'analyse en arrière-plan.

`lib/ocr.ts:118`

F19 Aucune limite de taille pour la lecture automatique des reçus

ÉLEVÉ · ○ Lu dans le code

CE QUI SE PASSE	L'envoi d'une note est limité à 10 Mo, mais l'analyse automatique du reçu accepte un fichier de n'importe quelle taille.
POURQUOI C'EST UN PROBLÈME	Un seul gros fichier peut occuper le serveur longtemps : c'est un moyen simple et peu coûteux de le rendre indisponible.
CE QU'IL FAUT FAIRE	Appliquer à l'analyse la même limite de taille qu'à l'envoi des notes.

`lib/ocr.ts:106`

F18 Les listes ne sont pas paginées

MOYEN · ● Vérifié

CE QUI SE PASSE	Toutes les listes (notes, validations, annuaire) renvoient l'intégralité des résultats d'un seul coup.
POURQUOI C'EST UN PROBLÈME	Avec beaucoup de données, les pages deviennent lentes à charger et le serveur consomme de plus en plus de mémoire.
CE QU'IL FAUT FAIRE	Paginer les listes.

`routes de liste employé, manager et RH`

F20 Aucune limite au nombre de tentatives

MOYEN · ○ Lu dans le code

CE QUI SE PASSE	Rien ne limite le nombre de tentatives de connexion, d'inscriptions ou d'analyses de reçus.
POURQUOI C'EST UN PROBLÈME	Un robot peut essayer des milliers de mots de passe, créer des comptes en masse ou surcharger le serveur.
CE QU'IL FAUT FAIRE	Limiter le nombre de requêtes par adresse IP et par compte.

`connexion · inscription · receipt-suggestion`

F21 Les traitements lourds font attendre l'utilisateur

MOYEN · ○ Lu dans le code

CE QUI SE PASSE	L'analyse des reçus et le chiffrement des mots de passe ont lieu pendant que l'utilisateur attend la réponse, sans file d'attente.
POURQUOI C'EST UN PROBLÈME	Les temps de réponse s'allongent, et le serveur supporte mal les pics d'activité.
CE QU'IL FAUT FAIRE	Passer les traitements lourds (analyse des reçus, notifications) en tâches de fond.

`lib/ocr.ts · bcryptjs`

F34 La limite de 10 Mo ne protège pas le serveur

MOYEN · ○ Lu dans le code

CE QUI SE PASSE	Le fichier envoyé est entièrement chargé en mémoire avant que sa taille soit vérifiée.
POURQUOI C'EST UN PROBLÈME	Un envoi de plusieurs centaines de Mo occupe la mémoire du serveur avant d'être refusé, aussi bien pour l'envoi d'une note que pour l'analyse d'un reçu.
CE QU'IL FAUT FAIRE	Refuser les envois trop gros avant de les lire, et fixer une limite au niveau du serveur web.

`api/expense-notes/route.ts:63, 84`

6. Sécurité technique

Failles liées à la configuration du serveur et à ce qu'il laisse voir de lui-même.

F25 La clé qui protège les sessions est écrite dans le code

CRITIQUE · ○ Lu dans le code

CE QUI SE PASSE	La clé secrète qui garantit l'authenticité des sessions est écrite en clair dans le code source, lui-même partagé sur le dépôt Git.
POURQUOI C'EST UN PROBLÈME	Toute personne ayant accès au dépôt peut fabriquer une session valide et se connecter sous l'identité de n'importe qui, y compris d'une RH.
CE QU'IL FAUT FAIRE	Lire la clé depuis la configuration du serveur, en générer une nouvelle et considérer l'ancienne comme compromise.

`lib/auth.ts:8`

F26 Les messages d'erreur exposent l'intérieur du serveur

ÉLEVÉ · ● Vérifié

CE QUI SE PASSE	En cas d'erreur, le serveur renvoie au navigateur le détail technique complet, y compris les chemins de fichiers du serveur.
POURQUOI C'EST UN PROBLÈME	Ces informations aident un attaquant à comprendre comment l'application est construite et à mieux cibler ses attaques.
CE QU'IL FAUT FAIRE	Afficher un message générique à l'utilisateur et garder le détail dans les journaux du serveur.

`lib/errors.ts:5`

F36 On peut deviner quels emails ont un compte

FAIBLE · ○ Lu dans le code

CE QUI SE PASSE	L'inscription répond « un compte existe déjà », et la connexion répond plus vite quand l'email n'existe pas.
POURQUOI C'EST UN PROBLÈME	Un attaquant peut dresser la liste des comptes existants avant d'essayer de deviner leurs mots de passe.
CE QU'IL FAUT FAIRE	Rendre les réponses, et leurs temps de réponse, identiques dans les deux cas.

`app/actions/auth.ts:38 · lib/auth.ts:35`

F37 Le contenu des fichiers envoyés n'est pas vérifié

FAIBLE · ○ Lu dans le code

CE QUI SE PASSE	L'application se fie au type de fichier annoncé par le navigateur, sans regarder le contenu réel.
POURQUOI C'EST UN PROBLÈME	Un fichier quelconque peut être enregistré comme « image » ou « PDF », puis ouvert par un manager ou une RH.
CE QU'IL FAUT FAIRE	Vérifier le contenu réel du fichier, et proposer les reçus en téléchargement plutôt qu'en affichage direct.

`api/expense-notes/route.ts:81`

7. Qualité du code

Ce qui rend le code plus difficile, et plus risqué, à faire évoluer.

F22 Une partie de l'architecture n'est pas utilisée

MOYEN · ● Vérifié

CE QUI SE PASSE	Le projet contient des couches prévues pour centraliser les règles métier, mais aucune page ne s'en sert : chaque route réécrit sa propre logique.
POURQUOI C'EST UN PROBLÈME	Les mêmes règles existent en double et peuvent diverger, et certaines fonctions prévues ne sont jamais appelées (voir F15).
CE QU'IL FAUT FAIRE	Soit faire passer les routes par ces couches, soit les supprimer.

`src/domain · src/ports · src/adapters`

F35 Aucun test automatisé

MOYEN · ○ Lu dans le code

CE QUI SE PASSE	Le projet ne contient aucun test automatisé ni intégration continue.
POURQUOI C'EST UN PROBLÈME	Rien ne garantit qu'une correction ne casse pas autre chose, ni qu'une faille corrigée ne réapparaîtra pas lors de la refonte.
CE QU'IL FAUT FAIRE	Écrire un test pour chaque problème corrigé, et lancer les tests automatiquement à chaque modification.

`package.json`

F23 Le même code est recopié en cinq endroits

FAIBLE · ● Vérifié

CE QUI SE PASSE	La même fonction de mise en forme des notes est recopiée dans cinq fichiers.
POURQUOI C'EST UN PROBLÈME	Une correction doit être faite cinq fois, avec le risque d'en oublier une.
CE QU'IL FAUT FAIRE	Regrouper cette fonction en un seul endroit.

`routes employé, manager et RH`

F24 Des utilitaires ne sont jamais utilisés

FAIBLE · ● Vérifié

CE QUI SE PASSE	Des fonctions de validation et de mise en forme existent mais ne servent nulle part ; chaque écran a sa propre version.
POURQUOI C'EST UN PROBLÈME	Du code mort qui encombre le projet et trompe sur ce qui est réellement utilisé.
CE QU'IL FAUT FAIRE	Les utiliser partout ou les supprimer.

`utils/validators.ts · utils/format.ts`

F27 Les codes d'erreur sont incohérents

FAIBLE · ● Vérifié

CE QUI SE PASSE	Un accès refusé renvoie le code 401 côté manager et le code 403 côté RH.
POURQUOI C'EST UN PROBLÈME	Les développeurs qui utilisent l'API ne peuvent pas traiter les refus de façon uniforme.
CE QU'IL FAUT FAIRE	Utiliser partout 401 pour « non connecté » et 403 pour « connecté mais pas autorisé ».

`routes manager et RH`

Plan d'action recommandé

Un ordre de correction proposé, du plus urgent au moins urgent. Chaque constat apparaît une seule fois.

Immédiatement

Failles critiques et fuites entre entreprises.

- Un manager peut voir les justificatifs de n'importe quelle entreprise F1
- Injection SQL possible via le tri de la liste des notes F3
- La clé qui protège les sessions est écrite dans le code F25
- La protection intégrée à la base de données est contournée F2
- La RH peut rattacher un employé à un manager d'une autre entreprise F5
- L'organigramme peut tourner en boucle F30
- Deux décisions simultanées sur une note peuvent toutes deux réussir F9
- Les messages d'erreur exposent l'intérieur du serveur F26

Avant la mise en service

Ce qui bloque un usage réel ou expose à une panne.

- Le premier inscrit d'un domaine devient RH, sans vérification F4
- Les majuscules dans l'email posent problème F7
- Un changement de rôle n'est pris en compte qu'à la reconnexion F31
- Un montant très élevé fait échouer l'envoi F13
- La date de la dépense n'est pas vérifiée F32
- Personne ne peut valider les notes de frais d'une RH F14
- Un nouvel employé n'a personne pour valider ses notes F33
- Aucun index sur les données les plus consultées F16
- La lecture automatique des reçus est lente et gourmande F17
- Aucune limite de taille pour la lecture automatique des reçus F19
- Aucune limite au nombre de tentatives F20
- La limite de 10 Mo ne protège pas le serveur F34
- Aucun test automatisé F35

Ensuite

Confort, maintenabilité et fonctions complémentaires.

- Une entreprise se résume à un nom de domaine F6
- Impossible de nommer un manager depuis l'application F8
- Une note peut être enregistrée sans son reçu F10
- Une inscription ratée peut laisser une entreprise sans RH F11
- Deux inscriptions simultanées avec le même email provoquent une erreur F12
- L'employé n'est jamais prévenu de la décision F15
- Les listes ne sont pas paginées F18
- Les traitements lourds font attendre l'utilisateur F21
- Une partie de l'architecture n'est pas utilisée F22
- Le même code est recopié en cinq endroits F23
- Des utilitaires ne sont jamais utilisés F24
- Les codes d'erreur sont incohérents F27
- Aucun historique des décisions F28
- Plusieurs défauts d'affichage F29
- On peut deviner quels emails ont un compte F36
- Le contenu des fichiers envoyés n'est pas vérifié F37
- Des fonctions attendues manquent F38

Annexe : méthode

L'application a été lancée en local dans sa configuration de développement (Next.js, PostgreSQL, stockage de fichiers compatible S3). Elle a été parcourue dans un vrai navigateur pour chaque rôle, puis les contrôles d'accès ont été rejoués directement sur l'API avec la session réelle de chaque rôle. Deux entreprises de test ont été créées pour vérifier le cloisonnement entre sociétés.

Les comptes manager et RH ne pouvant pas être attribués depuis l'interface (voir F8), ils ont été créés directement en base. Une seconde passe, le 12 octobre 2026, a consisté en une relecture complète du code ; elle a ajouté les constats F30 à F38, qui restent à reproduire sur l'application en marche.

Des données de test (deux entreprises jetables et quelques notes) sont restées dans la base de développement ; leur liste figure dans le rapport technique, en vue de leur nettoyage.